Esame di fine modulo

1. Quali azioni preventive si potrebbero implementare per difendere l'applicazione Web da attacchi di tipo SQLi oppure XSS da parte di un utente malintenzionato?

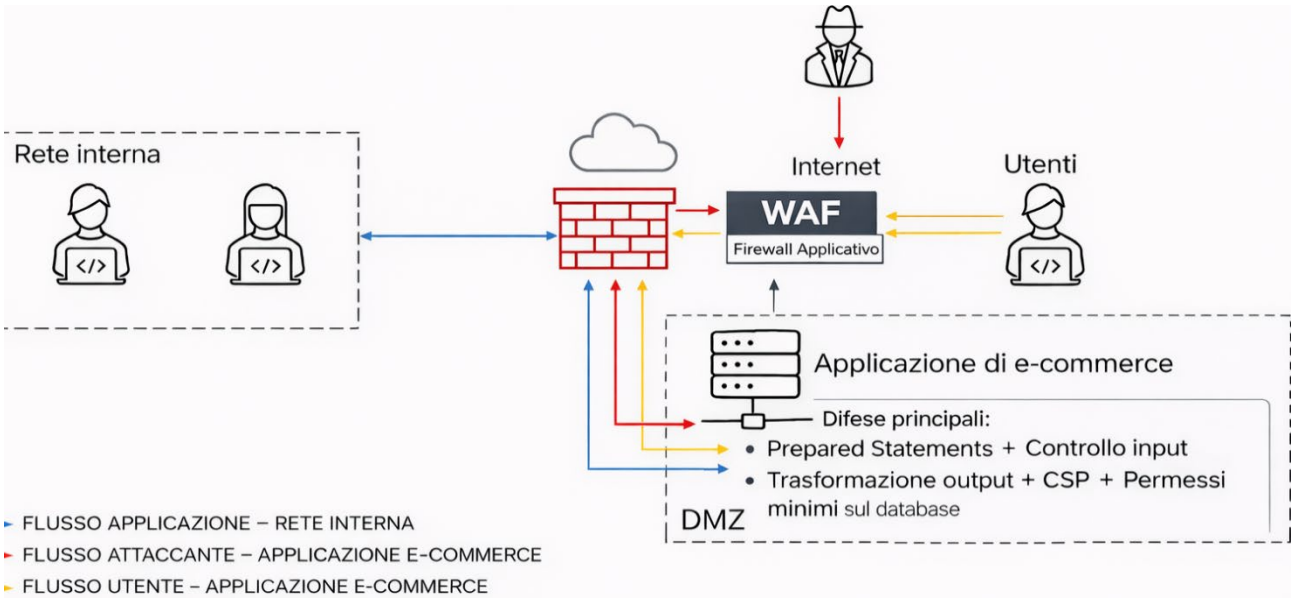
   Contro SQL Injection (SQLi) – quando qualcuno prova a inserire comandi malevoli nei campi di ricerca o login:

Usare sempre prepared statements. In pratica: invece di mettere direttamente il testo inserito dall'utente nella query al database, si usa un sistema che separa i dati dal comando. È il metodo più sicuro e quasi tutti i framework lo fanno già di default, se usati correttamente. Si può controllare bene ogni input, per esempio accettare solo numeri dove ci deve essere un numero. Dare al programma solo i permessi minimi sul database, non deve poter cancellare tabelle o modificare la struttura, e infine non mostrare mai all'utente messaggi di errore con dettagli del database.

Contro attacchi Cross-Site Scripting (XSS):

SI può mettere un header chiamato Content Security Policy (CSP) che dice al browser: "esegui solo script che vengono dal nostro sito, blocca tutto il resto", oppure impostare i cookie con le opzioni HttpOnly, Secure e SameSite per renderli più sicuri. E aggiungere un Web Application Firewall (WAF) che blocca automaticamente molti tentativi di XSS e SQLi prima che arrivino all'applicazione.

Un ultimo punto può essere la formazione del personale così da non cascare nelle e-mail di phishing o utilizzare credenziali complesse.



2. Impatti sul business: l'applicazione Web subisce un attacco di tipo DDoS dall'esterno che rende l'applicazione non raggiungibile per 10 minuti. Calcolare l'impatto sul business dovuto alla non raggiungibilità del servizio, considerando che in media ogni minuto gli utenti spendono 1.500 € sulla piattaforma di e-commerce. Fare eventuali valutazioni di azioni preventive che si possono applicare in questa problematica.

Fatturato medio al minuto: 1500€

Durata downtime: 10 minuti

Perdita stimata: 1500 x 10 = 15000€

Oltre alla perdita economica diretta, bisogna considerare la possibile perdita di fiducia da parte dei clienti, danno reputazionale e costi extra, intervento urgente del team IT, comunicazioni ai clienti ed eventuali rimborsi.

Per ridurre rischi di un attacco DDoS che blocca il sito:

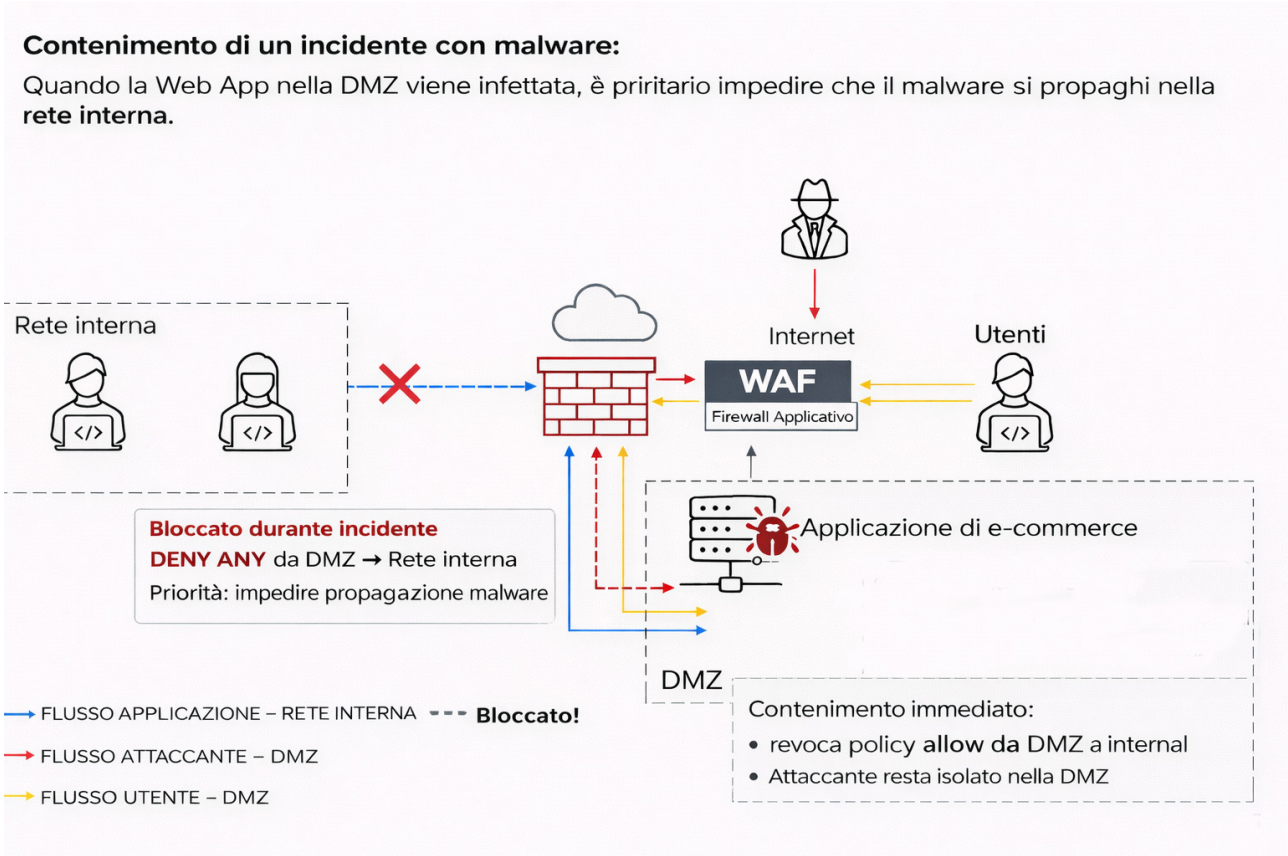
Usare una CDN (Content Delivery Network) con protezione DDoS integrata (es. Cloudflare, Akamai, Fastly, AWS Shield, Azure Front Door), la CDN assorbe e filtra tutto il traffico malevolo prima che arrivi ai tuoi server.

Impostare rate limiting e regole anti-bot per bloccare richieste sospette, monitoraggio continuo del traffico per accorgersi subito di anomalie. E infine avere load balancer con autoscaling automatico: se arriva tanto traffico legittimo, il sistema si allarga da solo.

3. Response: l'applicazione Web viene infettata da un malware che non si propaga nella vostra rete, mentre non siete interessati a rimuovere l'accesso da parte dell'attaccante alla macchina infetta.

L'azione principale è isolare il server compromesso per bloccare qualsiasi movimento laterale verso la rete interna. Sul firewall si deve bloccare tutto il traffico in uscita dalla DMZ verso la rete interna, bloccare anche il traffico in uscita dal server infetto verso Internet e mantenere attivo il monitoraggio.

Infine si potrebbe utilizzare un IDS/IPS, in questo caso che il danno e già avvenuto l'IDS e preferibile.



4. Modifiche «più aggressive» dell’infrastruttura (se necessario/facoltativo, magari integrando la soluzione al punto 2)

Budget disponibile: 30/40K

Con un budget di questo livello (non molto alto, ma per e-commerce medio piccoli ci sta), non si può fare una rivoluzione totale, ma si possono fare upgrade molto efficaci che migliorano drasticamente la sicurezza.

- Passare a Cloudflare Business Plan con DDoS avanzato e WAF gestito. Costo stimato circa 2400€ (200€ mese per dominio principale)
- Formazione del personale: Stima 1500€/anno
- Aggiunta di un IDS/IPS open-source nella DMZ, costo stimato: 5000-12000€/anno. Rileva anomalie, exploit noti (SQLi/XSS residui, scansioni).
- EDR leggero sui server DMZ (es. Microsoft Defender for Servers) 4000€/anno, rileva malware o processi sospetti sul server infetto.
- Infine, come ultima modifica che si potrebbe apportare fare un Penetration Test alla Web Application per rilevare eventuali vulnerabilità e mitigarle. Costo stimato Pen test: 6000€

Il totale per queste implementazioni di sicurezza e: 19.900€